UFCD 10795
Sala 7
Manoel Barata
Marco Iça
Sandra Mota

João é colaborador de uma empresa de consultoria financeira sediada em Lisboa. Desde a pandemia, trabalha em regime híbrido, alternando entre o escritório e a sua casa em Cascais. Num dia de trabalho remoto, João decide ligar-se à rede da empresa através do Wi-Fi público de um café local. Para aceder aos documentos internos, utiliza o portal interno da empresa, que exige autenticação, mas esquece-se de ligar a VPN corporativa, que normalmente cifra o tráfego e cria um túnel seguro entre o seu computador e o servidor da empresa.

Durante a tarde, a equipa de segurança informática deteta atividades suspeitas no servidor, há registos de acessos não autorizados a ficheiros de clientes, feitos a partir de um endereço IP localizado fora de Portugal.

A investigação revela que João foi vítima de um ataque "man-in-the-middle": um hacker interceptou a sua comunicação através da rede pública, capturando credenciais e dados sensíveis.

João, por sua vez, defende-se afirmando que nunca recebeu formação específica sobre VPN e que o manual interno não explicava de forma clara o seu uso obrigatório em contextos de teletrabalho.

1. Explique, em termos simples, o que é uma VPN e de que modo teria protegido a comunicação de João.

   Uma VPN é uma tecnologia que cria um túnel seguro e criptografado entre 2 pontos, permitindo a extensão de uma rede privada ou local.
   A VPN teria criptografado os dados, ou seja, mesmo que alguém interceptasse os dados serão ilegíveis.

2. Como deveriam as empresas formar os seus colaboradores para evitar situações semelhantes?

   As empresas deveriam formação onboarding e periódica aos seus colaboradores e criar um manual com linguagem acessível e de fácil entendimento para os seus colaboradores.
   Para além da formação, a própria empresa poderia tornar obrigatória a conexão via VPN quando em trabalho remoto.

3. Quais os riscos associados a serviços gratuitos de VPN?

   Os serviços gratuitos têm, por norma, configurações e oferta de protocolos limitados. Para alem disso, podem recolher dados dos utilizadores, ou ser fonte de malware, sendo que podem ser de fontes não confiáveis.

Perguntas técnicas:

- Quais os componentes técnicos centrais de uma VPN?

  Os componentes técnicos centrais de uma VPN são o cliente VPN, o servidor VPN, os protocolos de segurança (como OpenVPN, IPSec, IKEv2, WireGuard), o túnel VPN (a conexão segura e criptografada) e a criptografia e descriptografia dos dados.

- Que tipos de ataques uma VPN bem implementada pode mitigar, e quais não consegue impedir?

  Alguns tipos de ataque que podem mitigar são man-in-the-middle, criptografando os dados e tornando-os ilegíveis para o atacante; espionagem em redes publicas, impedindo que terceiros vejam o tráfego e spoofing de IP, ocultando o IP real.
  Os que não consegue impedir são malware ou phishing, não impedindo que o utilizador clique em links maliciosos; vulnerabilidades no software, sendo que se o cliente ou o servidor tiver falhas a VPN não as corrige, e contra manipulação humana,

- Se o software do lado do cliente ou do servidor tiver vulnerabilidades em que medida a VPN resolve ou não o problema?

  Uma VPN pode ajudar a proteger o tráfego que atravessa a rede, mas não resolve vulnerabilidades no software do cliente ou servidor, pois essas falhas residem no próprio programa e não na conexão de rede.
  Se a VPN estiver desatualizada, a criptografia não será tão eficaz, deixa o tráfego VPN exposto, e podem ficar vulneráveis a meios de força bruta ou métodos de criptoanálise.
  Se a VPN não for eficaz, pode ser vazado o IP ou dados transmitidos, não redirecionando o tráfego de internet, contrariando o objetivo da VPN.
  Se os protocolos utilizados não forem os mais eficazes ou atualizados, provocam vulnerabilidades no túnel, podendo permitir acesso aos dados transmitidos, ou acesso aos servidores das empresas